

Rapport technique - DataVision AI v2.81.1

1. Objet du document

Ce rapport décrit l'architecture, les composants, les flux, les mécanismes de gouvernance, les choix de sécurité, les capacités analytiques et les garanties de reproductibilité de DataVision AI v2.81.1.

La v2.81.1 est un correctif du jalon **Security & Documentation Freeze** qui précède la préparation de DataVision AI v3.0.0. Elle consolide l'authentification obligatoire, corrige les derniers défauts CI identifiés, renforce la chaîne de dépendances et formalise la documentation de production.

2. Finalité du produit

DataVision AI est une plateforme intégrée pour les professionnels de la donnée. Elle vise à regrouper dans un même environnement :

- ingestion de fichiers et connexion à des sources externes ;
- catalogage, profiling et qualité des données ;
- préparation et transformations versionnées ;
- SQL, statistiques et exploration ;
- visual analytics, dashboards et storytelling ;
- notebooks Python/R isolés ;
- AutoML, forecasting, anomalies, explicabilité et Responsible AI ;
- collaboration, revue, certification et gouvernance ;
- reporting et publication contrôlée ;
- assistant IA conversationnel contextuel ;
- opérations, observabilité, sauvegarde et reprise.

3. Architecture logique

Composant	Technologie / rôle	Responsabilité principale
Web	Next.js / React / TypeScript	Interface, authentification, cockpit, assistant, data workflows
API	FastAPI / Python	Services métier, sécurité, RBAC, gouvernance, analytics, ML
Worker	Python	Jobs asynchrones, refresh, scans, automatisations

Composant	Technologie / rôle	Responsabilité principale
PostgreSQL	SQL	Métadonnées, identité, sessions, workspaces, audit, politiques
Redis	Queue / coordination	Jobs, coordination et états opérationnels
Sandbox	Python/R isolé	Exécution notebooks hors du processus API
Stockage / connecteurs	Fichiers, S3-compatible, GCS, Azure Blob, DB/warehouses	Acquisition et synchronisation des données
Observabilité	métriques, traces, health, SLO	Exploitation et preuve de fiabilité

4. Architecture de déploiement

Le profil Docker Compose standard démarre les services Web, API, Worker, PostgreSQL, Redis et Sandbox, avec les composants d'observabilité prévus par le profil. Le profil Kubernetes s'appuie sur un chart Helm et sur des politiques Conftest/Rego.

Les services ne doivent pas être exposés directement sur Internet. En production, le frontend et l'API doivent être placés derrière un reverse proxy ou ingress TLS correctement configuré.

5. Modèle de données et versioning

Les datasets sont traités comme des objets versionnés. Une transformation produit une nouvelle version plutôt que de modifier silencieusement la version précédente. Les métadonnées conservent notamment :

- identifiant de dataset et de version ;
- parent/root lineage ;
- provenance et opération appliquée ;
- contexte workspace ;
- qualité et contrats applicables ;
- empreintes d'environnement pour les runs reproductibles.

Ce modèle permet rollback, audit, comparaison et reproductibilité.

6. Ingestion et connecteurs

Les sources supportées comprennent les imports fichiers ainsi que les connecteurs de bases/warehouses et object storage. La plateforme dispose également d'une ingestion CDC gouvernée avec checkpoints, déduplication d'événements, upsert/delete et matérialisation en versions immuables.

Les secrets de connexion ne doivent jamais être exposés dans les réponses API ou les logs utilisateur.

7. Qualité et préparation

Le pipeline qualité fournit profiling, détection de problèmes, plans de remédiation et prévisualisation avant application. Les corrections à risque ne sont pas appliquées silencieusement. Les transformations sont tracées et rejouables.

8. Analyse et visualisation

DataVision couvre :

- statistiques descriptives et tests analytiques ;
- SQL et NLQ gouvernés ;
- visualisations recommandées ;
- dashboards multi-vues ;
- filtres et cross-filter ;
- visual analytics conversationnel ;
- storytelling analytique avec claims reliés à des preuves.

9. Machine Learning et IA

Le moteur ML comprend classification, régression, clustering, forecasting et détection d'anomalies. Les fonctions avancées incluent :

- AutoML avec validation adaptée à la tâche ;
- registre de modèles et model cards ;
- XAI/importance/diagnostics ;
- garde-fous de sécurité ML ;
- évaluation et observabilité ;
- causalité observationnelle explicitement étiquetée comme telle.

10. Notebook Studio

Les notebooks Python/R s'exécutent dans un sandbox distinct du control plane. Les environnements sont décrits par manifests et verrous de dépendances. Une modification d'environnement invalide le kernel concerné afin d'éviter qu'un run utilise silencieusement une ancienne configuration.

L'usage de `exec/eval` nécessaire à l'exécution de cellules est confiné au runtime sandbox et n'est pas utilisé par le control plane API.

11. Assistant DataVision AI

L'assistant flottant est contextuel, redimensionnable et peut utiliser le dataset/workspace actif. Le Model Gateway permet les providers autorisés par la politique de confidentialité, notamment fournisseurs locaux et providers externes configurés.

L'assistant ne possède pas de canal privilégié lui permettant de contourner les contrôles d'accès : les actions passent par les mêmes frontières RBAC/workspace que l'interface.

12. Authentification et autorisation

En v2.81 :

- AUTH_MODE=required est la valeur par défaut ;
- les datasets, notebooks et outils assistant refusent l'accès anonyme ;
- un Bearer token valide et un workspace autorisé sont requis pour les surfaces gouvernées ;
- AUTH_MODE=local_dev existe uniquement pour un développement local volontaire et n'est pas accepté selon la sémantique production ;
- le premier démarrage local utilise une session d'initialisation interne, courte et HttpOnly ; aucun secret bootstrap n'est demandé à l'utilisateur ;
- une instance distante ne peut pas être réclamée depuis le navigateur : le premier owner y est créé depuis la console serveur ;
- les sessions sont persistées et révocables ;
- les refresh tokens sont rotatifs ;
- les nouveaux mots de passe utilisent une longueur minimale produit de 8 caractères et un script renforcé ($N=2^{17}$, $r=8$, $p=1$) ; pour un déploiement sans MFA, une politique plus longue reste recommandée ;
- WebAuthn/MFA, OIDC/SSO et SCIM sont disponibles pour les environnements concernés.

13. RBAC et isolation workspace

Les rôles incluent owner, admin, data scientist, analyst et viewer. Les permissions sont vérifiées par ressource et workspace. Un dataset doit être lié au workspace actif ; les politiques de ligne/colonne sont héritées le long du lineage selon les règles de gouvernance.

14. Secrets et chiffrement

Les secrets applicatifs et connecteurs peuvent être protégés par chiffrement applicatif/enveloppe et providers KMS : Vault Transit, AWS KMS, GCP KMS et Azure Key Vault.

Aucun secret réel ne doit être stocké dans Git, l'image Docker ou l'archive source. Le fichier .env est explicitement exclu de la release reproductible.

15. Supply chain et CI

La chaîne CI/release comprend notamment :

- repository hygiene ;
- compatibilité des dépendances ;
- installation Python et pip check ;
- typecheck/build frontend ;
- tests backend ;
- gates fonctionnels ;
- pip-audit / npm audit ;
- Trivy filesystem/image ;
- Helm render et Conftest ;
- E2E Playwright ;

- SBOM et provenance ;
- packaging reproductible et SHA-256.

16. Reproductibilité de release

Le script de release construit une archive ZIP déterministe avec horodatages fixes, tri stable des fichiers et manifeste interne contenant taille + SHA-256 de chaque fichier. Une seconde construction doit produire le même digest pour être considérée reproductible.

17. Observabilité et SLO

DataVision expose health/live, startup et readiness. Le cockpit opérationnel conserve des preuves SLO séparant les benchmarks locaux des preuves de cible réelle. Une preuve locale ne peut pas être présentée comme preuve production.

18. Résultats de validation v2.81

Validation locale du gel sécurité/documentation :

- 661 tests collectés au total ;
- 660 passés ;
- 1 ignoré ;
- 0 échec fonctionnel ;
- Security Documentation Acceptance : 12/12 ;
- Security Hardening Static Audit : 19/19 ;
- Repository Hygiene : OK ;
- Dependency Compatibility : OK ;
- Production Baseline : OK ;
- CDC : 97,3 %, 71 exigences implémentées, 4 partielles, 0 manquante.

Les contrôles qui nécessitent Internet, Docker ou la toolchain frontend complète doivent être reconfirmés dans la CI de release sur l'artefact exact.

19. Limites connues

Aucune suite automatisée ne permet d'affirmer « zéro vulnérabilité ». Les contrôles internes réduisent les risques, mais la mise en production stable requiert également :

- pentest indépendant ;
- scan des images finales par digest ;
- validation TLS/reverse proxy ;
- revue IAM/KMS ;
- UAT métier signée ;
- validation de l'infrastructure cible.

20. Références sécurité

La politique produit fixe un minimum de 8 caractères. NIST SP 800-63B recommande 15 caractères lorsqu'un mot de passe est utilisé comme facteur unique ; DataVision recommande

donc une politique plus longue ou MFA pour les déploiements concernés. Le stockage reste aligné sur le profil scrypt OWASP N=2¹⁷, r=8, p=1. Le plan de vérification applicative s'appuie sur OWASP ASVS 5.0. Ces références ne constituent pas une certification de sécurité et ne remplacent pas un pentest de l'environnement cible.